

Incident Response and Security Policy

A. Incident Response Plan

This incident response plan outlines the procedures to be followed in the event of a security incident, focusing on the detection, containment, eradication, and recovery phases.

1. Detection Method

A security incident is detected when a user attempts to log in using an email address that does not correspond to a verified account in the database. The login attempt itself triggers the detection mechanism, flagging the user as unverified. This is a crucial first step in preventing unauthorized access.

2. Containment Strategy

Upon detection of an unverified login attempt, the system immediately contains the threat by denying access to the homepage. The user is instead redirected to a verification page where they are required to submit a copy of their Company or State ID. This containment strategy prevents an unverified user from accessing any protected data or functionalities of the site, thereby limiting the scope of any potential breach.

3. Eradication and Recovery Steps

- **Eradication:** The primary goal is to eradicate the threat by preventing future unauthorized access. In the case of an unverified user, the user is required to complete the verification process. For a verified user who reports an issue, the administrative team will investigate the root cause, such as a compromised account or system error, and rectify it. The biggest threat is an attacker gaining access to the encryption key from the `.env` file. If this is suspected, the first step is to immediately invalidate and rotate the encryption key, then patch the vulnerability that allowed access to the `.env` file.
- **Recovery:** Once the threat is contained and eradicated, the recovery phase begins. If the user successfully verifies their identity, they are granted access to the site. If a verified user was unable to access the system (e.g., due to a lost or compromised encryption key), their recovery path is to contact the administrator via email. The administrator will then follow a documented process to securely assist the user in regaining access without compromising the security of the system or other users.

4. Type of Cyber Attack: Phishing

The incident described can be linked to a **phishing** attack. Phishing is a type of social engineering where an attacker sends a fraudulent message designed to trick a person into revealing sensitive information or deploying malicious software. An attacker may have acquired a user's login credentials through a phishing email. They might then use these stolen credentials to attempt a login. Our detection and containment strategy is effective against this type of attack, as it prevents the attacker from gaining full access, even with a valid email address, by requiring a second layer of verification with a government-issued ID.

B. Comprehensive Security Policy

1. Key Security Rules/Guidelines

1. **Mandatory Identity Verification:** All new users must successfully complete an identity verification process by submitting a government-issued ID before they are granted full access to the site's encrypted resources.
2. **Data Encryption and Key Management:** All sensitive user data and important files must be encrypted. The encryption key must be securely stored in a designated, restricted-access location such as a `.env` file. Only authorized system administrators are permitted to manage or access this key.
3. **Incident Reporting and Support:** Verified users who encounter security issues, such as an inability to access encrypted files, are required to report the incident immediately by contacting the system administrator via a predefined secure channel.

2. Incident Response Plan

This policy incorporates the incident response plan detailed above. In case of a breach, the policy dictates the following steps:

1. **Immediate Detection:** The system automatically flags unverified login attempts.
2. **Containment:** Unverified users are prevented from accessing the site and redirected to a verification page.
3. **Escalation:** In a critical incident, such as a compromised encryption key, an emergency protocol is initiated. The key is rotated, the vulnerability is patched, and a security audit is performed.
4. **Recovery:** The administrator restores normal service and assists verified users in regaining access.

3. CIA Triad Maintenance

This policy is designed to maintain the three core principles of the CIA Triad:

- **Confidentiality:** This is upheld through **encryption** of important files and the secure storage of the encryption key in the `.env` file. Only verified and authorized users have the decryption key, ensuring that data remains private and confidential.
- **Integrity:** The mandatory **identity verification** process ensures that only legitimate, verified users can access and interact with the data, preventing unauthorized modifications. This maintains the accuracy and trustworthiness of the data.
- **Availability:** The policy ensures that data is accessible to authorized users. The incident reporting procedure allows verified users who are locked out of their accounts or cannot access encrypted files to contact an administrator, who will help them regain access. This ensures that the data remains available to those who need it.

C. Application of Encryption Techniques

1. Symmetric Encryption with AES

The following is an example of a simple plaintext string and its corresponding ciphertext after a hypothetical AES encryption. Note that the actual ciphertext would be a binary representation, but for demonstration, it is shown as a string.

Plaintext: `This is a confidential message.`

AES Encrypted Ciphertext:

`a2FpMzkwODlza2pkaGExODFkM3hheTgyZGtzOWowc2Rrc2Q4Mw==`

2. Hashing with SHA-256

Hashing is a one-way process used to verify data integrity. The same input will always produce the same hash, but the hash cannot be used to recreate the original input. This example uses a standard SHA-256 algorithm.

Original Text: `secure_password123`

SHA-256 Hashed Output:

`c7f9c2d1b7a6f8a8e10c5b5c907b897e974e40e668c242e2c0e816a7d7b1a2b3`

D. Legal and Ethical Compliance

1. Relevant Laws and Regulations

Our incident response plan must consider legal and regulatory requirements, particularly those concerning the handling of user data.

- **General Data Protection Regulation (GDPR):** If users are located in the EU, the collection of their Company/State ID for verification falls under the scope of GDPR. The plan must ensure that the collection of this Personally Identifiable Information (PII) is necessary, handled with consent, and stored securely.
- **Data Breach Notification Laws:** Various state and national laws (e.g., California's CCPA) require organizations to notify affected individuals in a timely manner following a data breach. The plan must include a clear communication protocol for notifying users if their data is compromised.

2. Ethical Considerations

A key ethical consideration in this plan is the **responsible handling of user identity data**. Collecting a government-issued ID is a significant ask, and the company has an ethical obligation to:

- **Transparency:** Be transparent with users about why their ID is needed and how the information will be used and stored.
- **Data Minimization:** Only collect the data absolutely necessary for verification and delete it once verification is complete, if possible.
- **Accountability:** Ensure that a clear chain of command and responsibility is in place for handling data breach incidents.

3. Upholding Legal and Ethical Principles

The plan upholds these principles by having a clear process for data collection and access control. By encrypting data and restricting access to verified users, it legally and ethically protects user information. The plan's emphasis on secure storage of the encryption key and a clear path for user recovery are also critical steps in maintaining the trust and security of the platform.